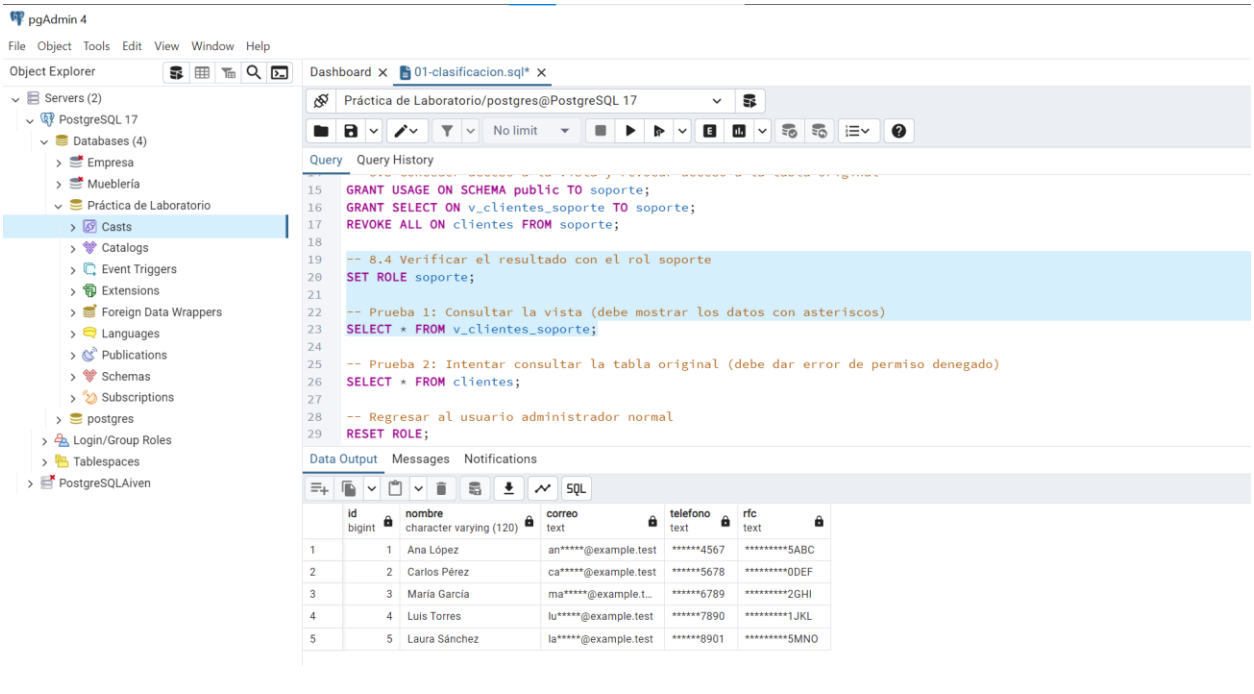
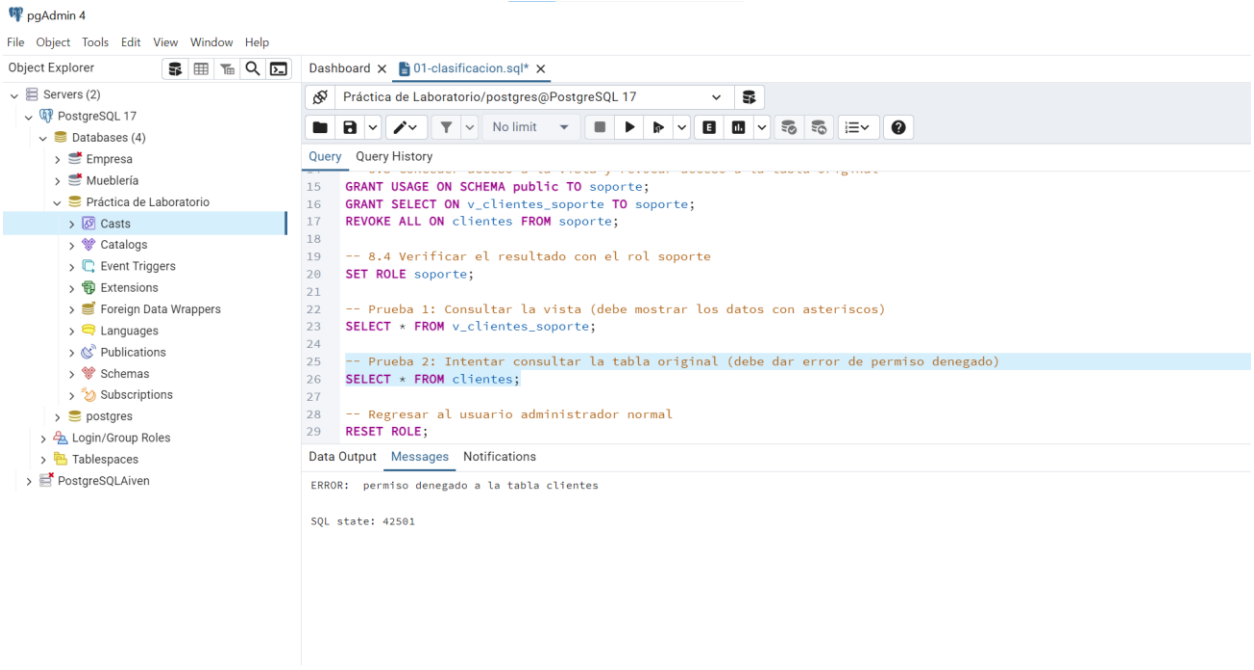
Actividad 2 - Enmascaramiento (masking)

Estudiante: Jesús Jared Recio Ozua

Fecha: 22 de octubre de 2026

Capturas de pantalla





Explicación del mecanismo y permisos aplicados

Se implementó un mecanismo de enmascaramiento dinámico mediante la creación de la vista v_clientes_soporte en PostgreSQL, utilizando funciones de manipulación de cadenas (CONCAT, LEFT, RIGHT y SUBSTRING) para ocultar parcialmente el correo electrónico, teléfono y RFC al momento de la consulta sin alterar los datos almacenados en la tabla física. A nivel de control de acceso, se creó el rol soporte NOLOGIN, se le otorgó permiso de uso del esquema (GRANT USAGE ON SCHEMA public) y permiso de lectura exclusivo sobre la vista (GRANT SELECT ON v_clientes_soporte), revocando cualquier privilegio directo sobre la tabla original (REVOKE ALL ON clientes FROM soporte).

Preguntas de la Actividad 2

1. ¿Qué información continúa existiendo en la tabla original?

En la tabla original clientes continúan existiendo todos los datos íntegros, completos y sin ninguna modificación (id, nombre, correo, telefono, rfc, edad, ciudad, codigo_postal y fecha_alta), ya que el enmascaramiento mediante vistas solo transforma la presentación del dato al consultarlo.

2. ¿Qué información puede visualizar el usuario soporte?

El rol soporte únicamente puede visualizar el id, el nombre completo, los primeros 2 caracteres y el dominio del correo, los últimos 4 dígitos del telefono y los últimos 4 caracteres del rfc. No tiene visibilidad sobre la edad, ciudad, código postal ni fecha de alta.

3. ¿Por qué no es suficiente ocultar los datos únicamente en la aplicación?

Porque ocultar datos solo en el *frontend* o capa de aplicación deja expuesta la base de datos si un usuario, analista o atacante se conecta directamente al motor mediante un cliente SQL (como pgAdmin), herramientas de reportes o explota una vulnerabilidad de inyección SQL. El control debe aplicarse desde el motor de base de datos para garantizar el principio de mínimo privilegio.

4. ¿Qué ocurriría si soporte tuviera acceso directo a clientes?

El enmascaramiento perdería toda su efectividad como control de seguridad, ya que el usuario con el rol soporte podría ignorar la vista v_clientes_soporte y ejecutar directamente SELECT * FROM clientes; para obtener los datos personales y fiscales completos en texto claro.